

Risk Scoring Report

Project: **vulnerable-invoice-service** · Stage 2 (NVD CVSS-weighted) · Generated 2026-06-10 · Model: $0.5 \cdot \text{CVE} + 0.3 \cdot \text{exposure} + 0.2 \cdot \text{criticality}$

Ranked remediation backlog

#	Coordinate	Ver	Band	Risk	Top CVE / issue	Fix
1	log4j-core	2.14.1	HIGH	7.8	CVE-2021-44228 (10.0)	2.17.1
2	log4j-api	2.14.1	HIGH	7.8	CVE-2021-44228 (10.0)	2.17.1
3	jackson-databind	2.9.8	HIGH	7.8	CVE-2019-14379 (9.8)	2.13.4.2
4	com.fastxml...jackson-databind	2.9.8	CRITICAL	—	Typosquat (REMOVE)	remove
5	guava	24.1.1-jre	HIGH	6.0	CVE-2023-2976	32.0.0-jre
6	mysql-connector-java	8.0.30	MEDIUM	3.1	GPL-2.0 license	8.0.33
7	commons-io	2.4	LOW	2.5	outdated	2.18.0
8	commons-lang3	3.4	LOW	2.5	outdated	3.17.0
9	junit-jupiter	5.10.2	LOW	1.7	test-scope, outdated	5.13.0

Component scores (top items)

Dependency	CVE severity	Exposure	Business criticality	Weighted
log4j-core	10.0	8.0	2.0	7.8
jackson-databind	10.0	8.0	2.0	7.8
guava	6.9	7.0	2.0	6.0
mysql-connector-java	0.0	7.0	5.0	3.1

Priority recommendations

- P0** — Remove the typosquatted `com.fastxml.jackson.core` dependency (supply-chain).
- P0** — Upgrade log4j 2.14.1 → 2.17.1 (Log4Shell, actively exploited).
- P1** — Upgrade jackson-databind 2.9.8 → 2.13.4.2 (8 CVEs, 2 critical RCE chains).
- P1** — Upgrade guava → 32.0.0-jre (major review — API breakage possible).
- P2** — Resolve mysql-connector GPL-2.0 license violation.
- P3** — Routine bumps: commons-io, commons-lang3.

Machine-readable source: `depscan-risk-report.json` . Generated by the Dependency & Supply-Chain Plugin — Stage 2.